ÉVALUER LE NIVEAU DE SÉCURITÉ DES DONNÉES PERSONNELLES DE MON ORGANISME

Avez-vous pensé à... ?

FICHES		MESURES	
1	Piloter la sécurité des données	Faire de la sécurité un enjeu partagé et porté par l'équipe dirigeante	☐
		Évaluer régulièrement l'efficacité des mesures de sécurité mises en œuvre et adopter une démarche d'amélioration continue	☐
2	Définir un cadre pour les utilisateurs	Rédiger une charte informatique comprenant les modalités d'utilisation des systèmes informatiques, les règles de sécurité et les moyens d'administration en place	☐
		Donner une force contraignante à la charte et y rappeler les sanctions encourues en cas de non-respect	☐
3	Impliquer et former les utilisateurs	Sensibiliser les personnes manipulant les données	☐
		Adapter le contenu des sensibilisations à la population ciblée et à leurs tâches	☐
4	Authentifier les utilisateurs	Octroyer un identifiant (« *login* ») unique à chaque utilisateur	☐
		Adopter une politique de mot de passe conforme aux recommandations de la CNIL	☐
		Obliger l'utilisateur à changer le mot de passe attribué automatiquement ou par un administrateur	☐
5	Gérer les habilitations	Définir des profils d'habilitation	☐
		Supprimer les permissions d'accès obsolètes	☐
		Réaliser une revue annuelle des habilitations	☐
6	Sécuriser les postes de travail	Prévoir une procédure de verrouillage automatique de session	☐
		Installer et configurer un pare-feu (« *firewall* » en anglais) logiciel	☐
		Utiliser des antivirus régulièrement mis à jour	☐
		Recueillir l'accord de l'utilisateur avant toute intervention sur son poste	☐
7	Sécuriser l'informatique mobile	Sensibiliser les utilisateurs aux risques spécifiques du nomadisme	☐
		Prévoir des moyens de chiffrement des équipements mobiles	☐
		Exiger un secret pour le déverrouillage des smartphones	☐
8	Protéger le réseau informatique	Limiter les flux réseau au strict nécessaire	☐
		Sécuriser les réseaux Wi-Fi, notamment en mettant en œuvre le protocole WPA3	☐
		Sécuriser les accès distants des appareils informatiques nomades par VPN	☐
		Cloisonner le réseau, entre autres en mettant en place une DMZ (zone démilitarisée)	☐
9	Sécuriser les serveurs	Désinstaller ou désactiver les services et interfaces inutiles	☐
		Limiter l'accès aux outils et interfaces d'administration aux seules personnes habilitées	☐
		Installer sans délai les mises à jour critiques après les avoir testées le cas échéant	☐